Olivia Sope – GA2A

Custom challenge: Wordpress Password Attack
Session 2 (week of 10 September 2023)

Instruction:

I have designed a WordPress website -- http://localhost/cybersec/wp-admin/profile.php. The login page has a weakness.
There are two usernames on the website. Find them --Whatever that is needed to solve this challenge is there by accessing the website's pages. Do NOT look or modify anything in the website's files and folders or the database.

Steps undertaken to solve the challenge:

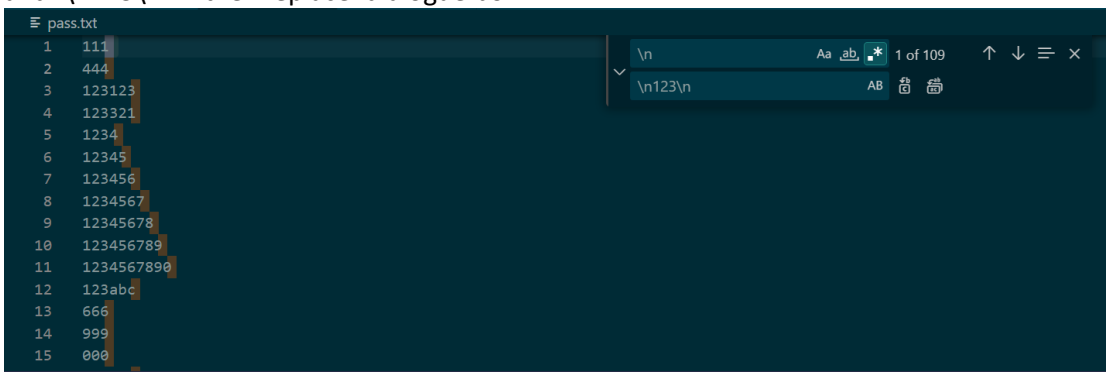
1. Open xampp and start Apache and MySQL. Turn on foxyproxy.
2. We were given username 'think and password '123' to login to the website. We were also given another 'admin', but do not know yet its password and must figure it out. By default, after 3 consecutive failed attempts Wordpress would block the next login attempt for 10 minutes.

   From the login trials, we've learned that a good strategy would be to create sequence of login attempts containing several pairs of username and password, i.e., think/123 and admin/unknown password.

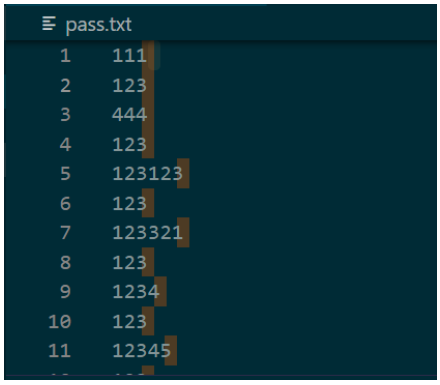
   We have been given a list of 110 passwords and need to pair individual passwords with each 'admin' username. Then we need to combine that 110 pairs with that of 'think/123' (also 110 pairs) making the total of 220 user-password list.

3. In VS Code, create 2 lists of text file for: 1) user (call it user.txt) and password (name it pass.txt). The user.txt file will contain 'think' and 'admin' alternately –total would be 220 (i.e., 110 'think' and 110 'admin'). For the pass.txt file, copy and paste from the given 'Hint_passwords.txt' file. This can be done by executing 'touch user.txt' in the terminal and type 'think' and 'admin'.

   Then execute 'touch pass.txt' and copy and paste the passwords. Insert '123' in between the existing passwords –this can be done by executing 'Ctrl + H', and type '\n' in 'Find' dialogue box and '\n123\n' in the 'Replace' dialogue box.

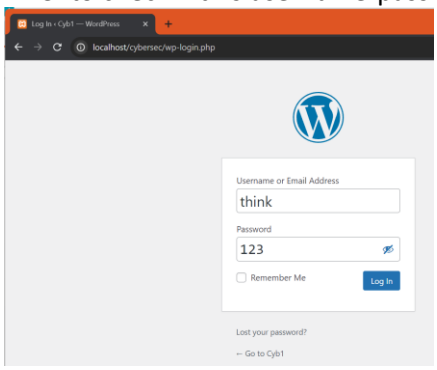


   Run the command and you should have '123' inserted in between the original passwords:

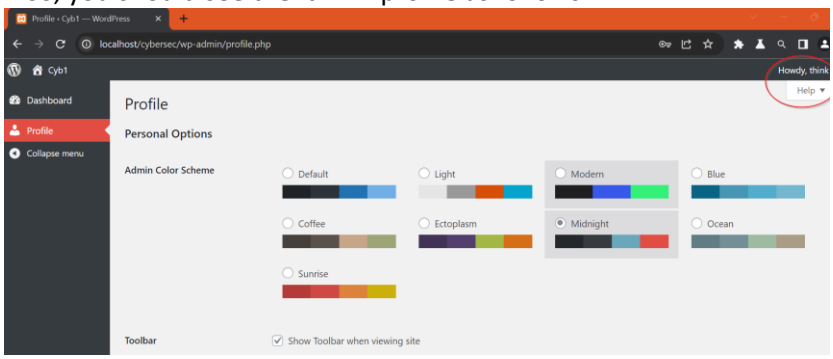


Since 'think' is the first username, make sure its password pair '123' is also the first passwords in the respective list. Manually insert '123' in line 1 and press Enter –now the initially first password of '111' is on line 2 and total number of passwords is 220. Save the files in the correct folder or create one if you have not already.

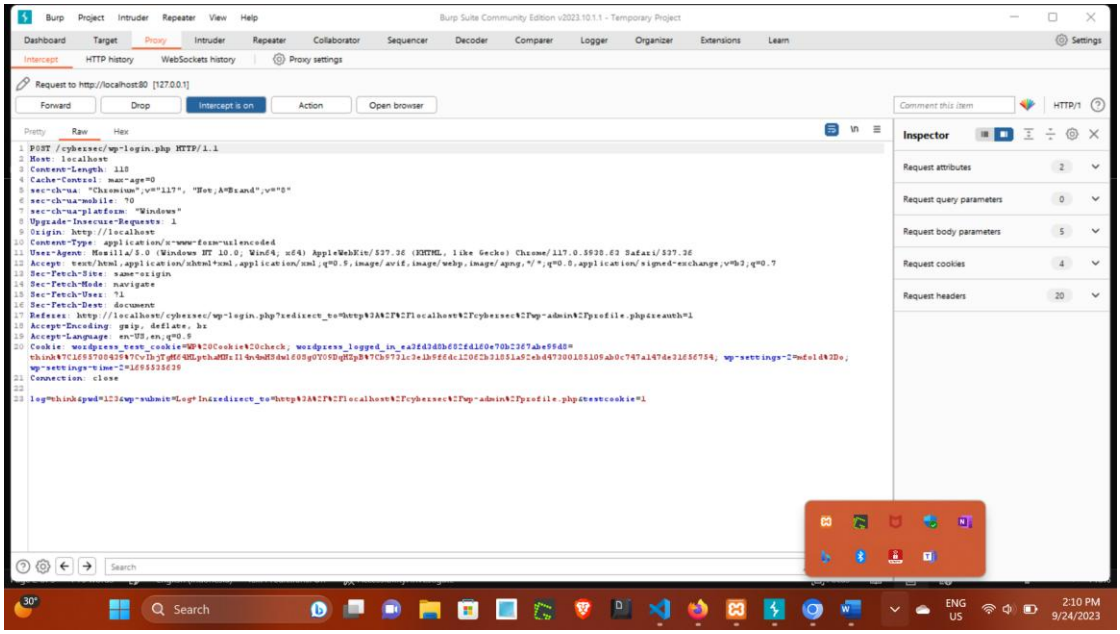
4. Go to localhost/cybersec/wp-login.php and login with the given username 'think and password '123' to check if this username-password is correct:



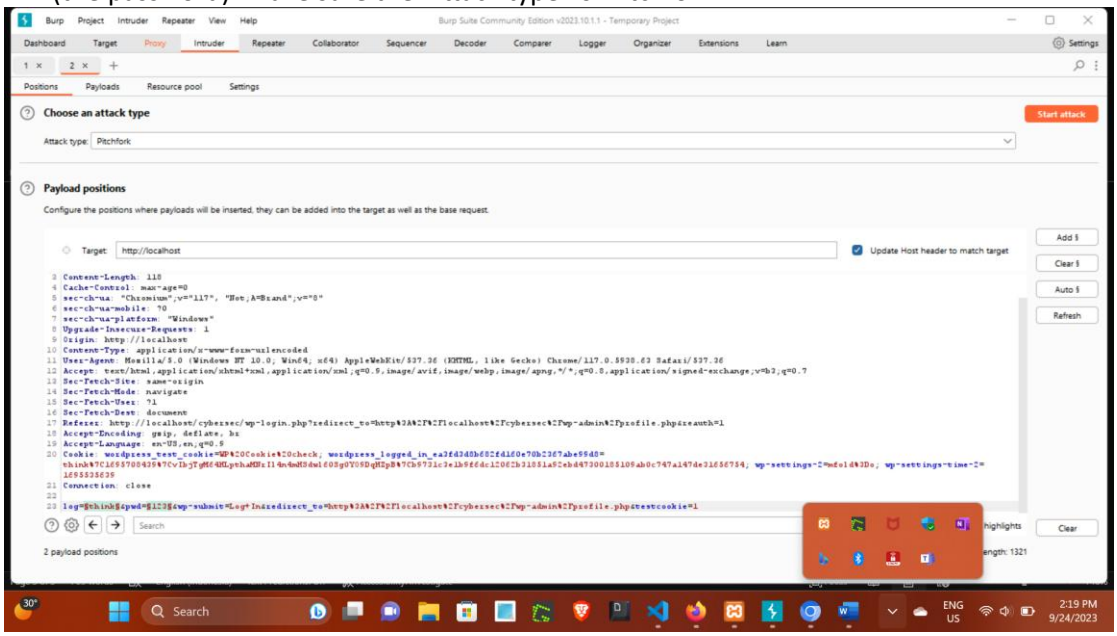
If so, you should see the 'think' profile as follows:



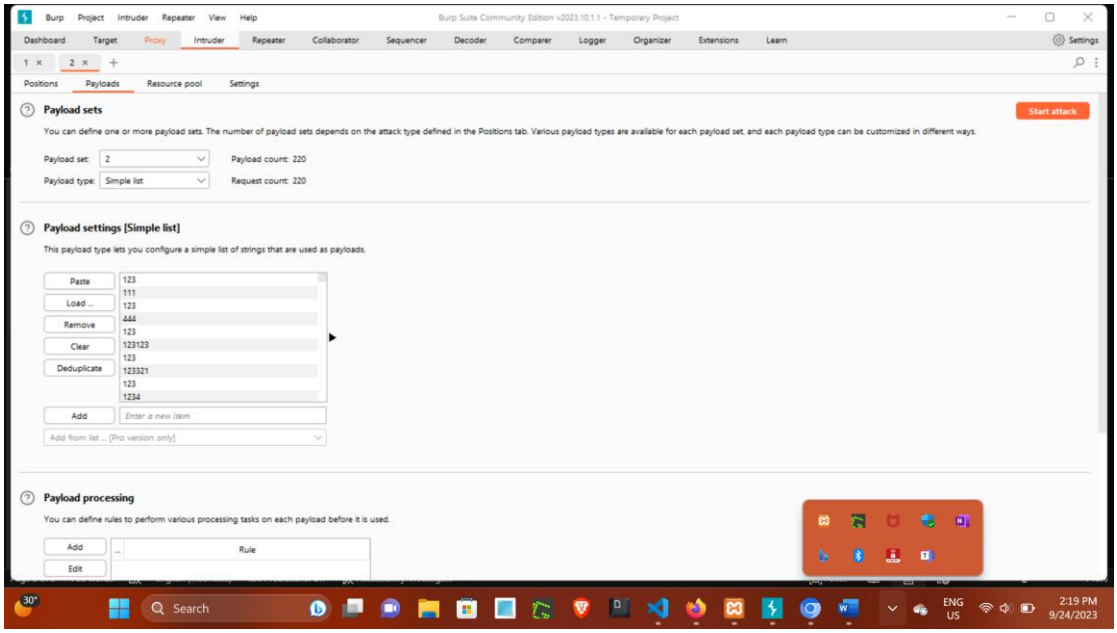
5. Start Burp Suite. Under Proxy >> Intercept, turn on Intercept. In the Raw section, right-click and select 'Send to Intruder'.



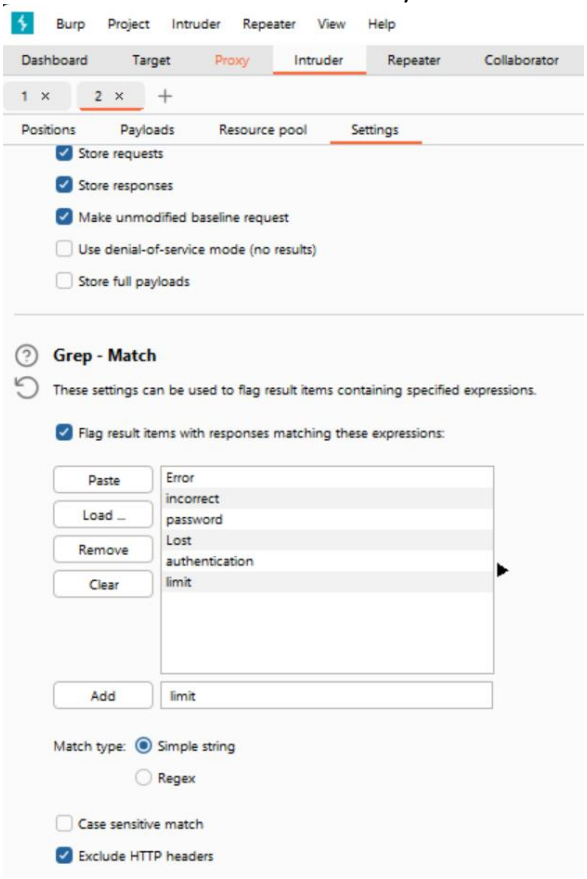
6. In the 'Intruder', do the following steps:
   - In the 'Positions' section, select/highlight 'think' and click 'Add' button. Do the same for '123' (the password). Make sure the 'Attack type' is 'Pitchfork'.



   - In the 'Payloads' section, select '2' for the Payload set: 1 for username and 1 for password. On Payload 1, copy and paste users from user.txt. Click the drop-down arrow and select Payload 2, copy and paste the passwords from pass.txt. By now, you should see that you have 220 Payload count and 200 Request count.



- In the 'Setting', scroll down to 'Grep Match' and enter a few response types in the box, e.g., Error, incorrect, password, etc. Select words that would help you identify whether the expected Status is either successful or unsuccessful (the 'Status' column would appear in the results after you commit 'Start Attack'). In this challenge, the selected response types indicate unsuccessful login. The result of 'admin' usernames having 302 status that **do not** contain these words would show you the correct password.

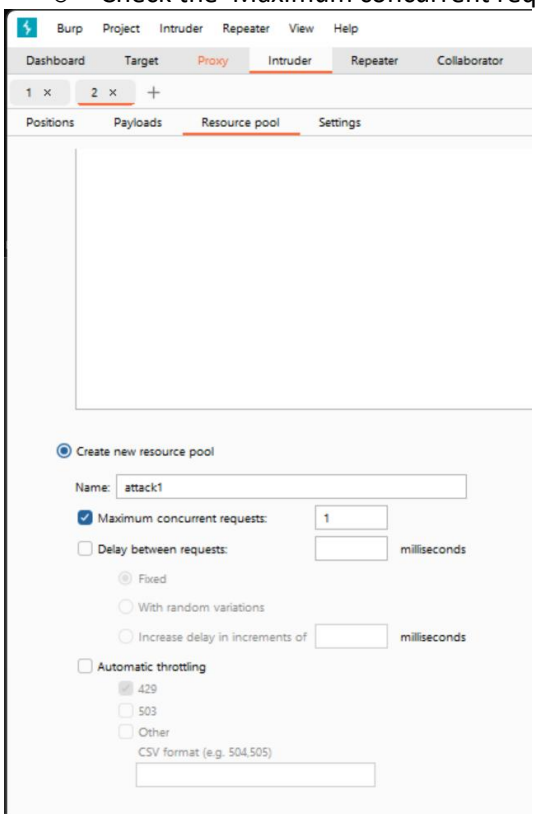


- Go to the 'Resource Pool' section –by default, you'll have 10 Concurrent requests if you're using the Burp Suite Community version. Ten (10) Concurrent requests might increase your

risk of getting blocked out of the system (for 10 minutes) if 1 of the first 10 requests (i.e., the username-password pair) were incorrect. This is the reason why we alternate between the 'think/123' and 'admin/password' pair, i.e., to increase of getting the correct pair.

Burp suite allows us to overcome this limitation by doing the following:

- Click on the 'Create new resource pool', go to 'Name' and type 'attack1'.
- Check the 'Maximum concurrent requests' box and type '1' in the box.

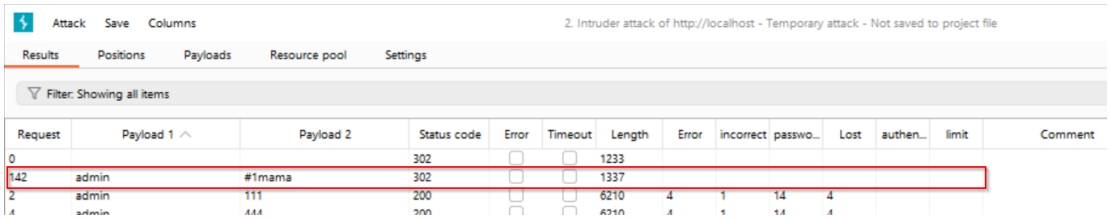


If deemed necessary, you can further specify the 'Delay between requests' check box. I decided to not undertake this step for this custom challenge.

7. Click on the 'Start Attack' button –you'll see this button in almost every section.

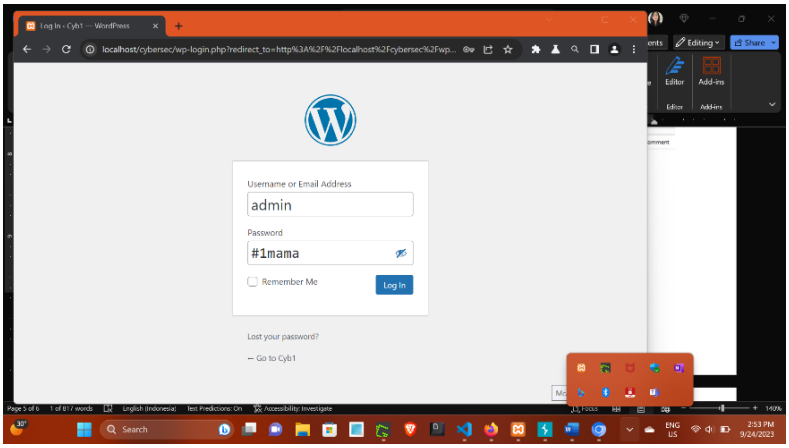
8. Once you get the results, analyse them. Pay attention to the 'Status' (look for 302 indicating 'Found', 'admin' user, 'response type' (specified in step #7 under 'Grep Match') and, if needed, the 'Length' should help you identify the correct password you are looking for.

   Sort the results by 'Status Code' (make 302 appears on top) and by 'admin' (under Payload1) and you will see line 142 does not contain the specified response types and gives you the password: '**#1mama**'

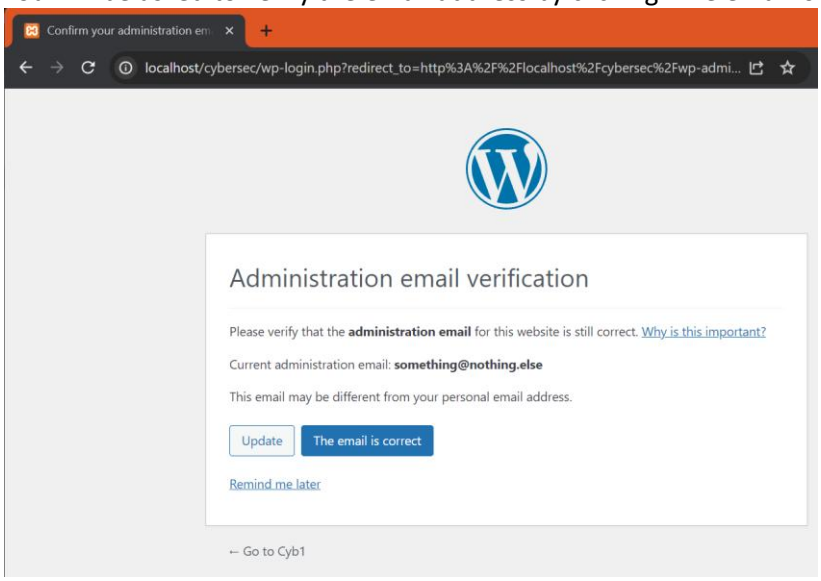


In this case, line 142 is worth inspecting as it has the username 'admin', 302 status, and do not contain response types indicating unsuccessful login. It gives the password: '**#1mama**'

9. Test if the identified password ‘’ is correct by logging back into the website using the username ‘admin’ and password ‘**#1mama**’:



You will be asked to verify the email address by clicking ‘The email is correct’ button:



And can successfully login as ‘admin’:

